GreenLeaf Microfinance

ACCESS CONTROL POLICY

ISO/IEC 27001:2022 | Draft Version 1.0

1. Purpose

The purpose of this Access Control Policy is to establish security requirements for managing and protecting access to GreenLeaf Microfinance information systems, applications, and sensitive data.

This policy aims to prevent unauthorized access, protect borrower information, and ensure that users receive only the permissions necessary to perform their assigned responsibilities.

The policy supports ISO/IEC 27001:2022 Annex A controls A.5.15 (Access Control), A.5.16 (Identity Management), A.5.18 (Access Rights), A.8.3 (Information Access Restriction), and A.8.5 (Secure Authentication).

2. Scope

This policy is intended to apply to GreenLeaf Microfinance employees, administrators, developers, contractors, and authorized third parties who access organizational systems.

Covered systems include:

- The GreenLeaf web portal and planned Android application.
- Borrower records and financial information.
- Application servers, databases, and cloud infrastructure.
- Development, testing, and production environments.
- Administrative accounts and source-code repositories.

The existing GreenLeaf sandbox is a fictional training environment. The requirements in this document represent proposed security controls and must not be interpreted as evidence that these controls are already operational.

3. Roles and Responsibilities

Management: Approves this policy, assigns accountable owners, and provides resources for implementation.

Information Security / GRC Lead: Maintains the policy, reviews access-control risks, coordinates periodic access reviews, and documents exceptions.

System Administrators: Provision, modify, disable, and remove accounts based on documented authorization.

Application Developers: Implement secure authentication, server-side authorization, session management, and access restrictions within applications.

Department Managers: Approve access requests based on job responsibilities and notify administrators when access requirements change.

Employees and Contractors: Protect account credentials, use authorized access only, and report suspected unauthorized access promptly.

4. Access Control Principles

GreenLeaf Microfinance shall implement access controls based on the principles of least privilege, need-to-know, and separation of duties.

Access to systems, applications, and borrower information shall be granted only to authorized individuals with a legitimate business requirement.

Role-Based Access Control (RBAC) shall be used where appropriate to restrict permissions according to assigned job responsibilities.

Access privileges shall be reviewed whenever an employee's responsibilities change.

Role Matrix and Access Review Requirements

All GreenLeaf user accounts shall be assigned a documented role based on least-privilege principles. Role definitions, permitted actions, and access permissions shall be maintained in the GreenLeaf Role Matrix (Appendix A).

The Information Security / GRC Lead shall coordinate quarterly access-review meetings with designated system owners. Review decisions, approvals, identified excessive permissions, and corrective actions shall be documented in a signed Access-Review Log.

Any change to protected application routes or role permissions shall require documented approval from the designated system owner and shall be recorded in the change-control log before deployment, except for authorized emergency changes, which shall be reviewed retrospectively.

Remediation Reference: A.5.15-01: Establish the GreenLeaf Role Matrix, implement quarterly access reviews, and maintain documented approval records for access-control changes.

Required Audit Evidence: Approved GreenLeaf Role Matrix, signed quarterly Access-Review Log, and approved change-control records.

ISO Reference: A.5.15, A.5.18, A.8.3

5. User Account Management

All users shall be assigned unique accounts. Shared accounts shall be prohibited unless a documented exception is approved.

New accounts shall be created only after receiving authorization from the relevant department manager or designated system owner.

Access requests shall specify the user's identity, business justification, requested permissions, and approval.

Accounts shall be modified when job responsibilities change and disabled promptly following termination or loss of authorization.

User access shall be reviewed at least quarterly for privileged accounts and every six months for standard accounts. These intervals are proposed policy requirements, not verified existing practices.

ISO Reference: A.5.16, A.5.18

6. Authentication and Password Security

All organizational systems shall require secure authentication before granting access to protected resources.

Multi-factor authentication (MFA) shall be required for administrative accounts and remote access to sensitive systems. MFA should also be implemented for access to borrower and financial information where technically feasible.

Passwords shall be protected using approved cryptographic password-hashing methods. Plaintext password storage is prohibited.

Default credentials shall be changed or disabled before systems are deployed.

Authentication failures shall be logged and monitored. Rate limiting or equivalent protections shall be implemented to reduce automated login attacks.

ISO Reference: A.5.17, A.8.5

7. Privileged Access Management

Administrative privileges shall be restricted to authorized personnel who require them for their duties.

Privileged accounts shall be separate from ordinary user accounts wherever technically feasible.

Administrative activities shall be logged, monitored, and reviewed for suspicious behavior.

Temporary elevated permissions shall have a defined expiration or removal process.

ISO Reference: A.8.2, A.8.3, A.8.15

8. Application and Data Access Restrictions

The GreenLeaf web portal and planned Android application shall enforce access restrictions on the server side.

Sensitive borrower information shall not be accessible through publicly exposed endpoints without appropriate authentication and authorization.

Application permissions shall be validated for every protected request, including requests involving borrower records and administrative functions.

Developers shall test unauthorized access attempts, including requests made without authentication and attempts to access another user's records.

Access-control failures shall be documented and addressed before introducing real customer data.

ISO Reference: A.8.3, A.8.5

Related Task 4 Remediation Actions: Implement server-side authentication and role-based authorization, restrict access to borrower records, establish approved access-control procedures, and verify that anonymous requests cannot retrieve protected information.

9. Access Monitoring and Audit Logging

GreenLeaf Microfinance shall maintain audit logs for authentication attempts, privileged account activities, access changes, and unauthorized access attempts.

Security logs shall be protected against unauthorized modification and reviewed according to documented risk-based procedures.

Suspicious access events shall be reported and investigated under the Incident Response Policy.

ISO References: A.8.15, A.8.16

10. Policy Exceptions

Exceptions to this policy shall require documented justification, risk assessment, approval from the designated Information Security / GRC Lead and system owner, and an expiration or review date.

Approved exceptions shall be recorded in an exception register and reviewed periodically.

Exceptions shall not permit uncontrolled exposure of borrower information.

ISO References: A.5.15, A.5.18

11. Compliance and Enforcement

Employees, contractors, and authorized third parties shall comply with this policy when accessing GreenLeaf systems.

Suspected violations shall be investigated and documented. Corrective measures may include access removal, additional training, or disciplinary action consistent with applicable requirement
The Information Security / GRC Lead shall coordinate compliance reviews and track remediation activities.

ISO References: A.5.36, A.6.4

12. Policy Review and Maintenance

This policy shall be reviewed at least annually and whenever significant changes occur to GreenLeaf systems, business processes, or applicable security requirements.

Reviews shall consider access-control incidents, audit findings, changes in risk exposure, and remediation progress.

All policy revisions shall be documented and submitted for approval.

ISO Reference: A.5.1

13. Document Control and Approval

Document Title: GreenLeaf Microfinance Access Control Policy

Version: 1.0 (Draft)

Document Owner: Information Security / GRC Lead (proposed)

Approval Authority: GreenLeaf Management (proposed)

Effective Date: Pending approval

Review Frequency: Annually or following significant changes

Approval Status: Draft for educational simulation; not formally approved

Related Remediation References

This policy supports the following findings from the GreenLeaf Task 4 gap analysis:

- A.5.15: Approve an organization-specific access-control policy, define roles and access reviews, and enforce authorization on protected routes.
- A.8.3: Require server-side authentication and role-based authorization before any real borrower records are accessible.
- A.8.5: Implement secure server-side authentication and sessions before introducing real users or sensitive data.
- A.8.15 and A.8.16: Establish logging and monitoring procedures and collect supporting operational evidence.

These are proposed controls and remediation requirements. Their implementation and effectiveness have not been verified in a production environment.

Appendix A: GreenLeaf Role Matrix (Proposed)

This appendix defines the proposed role-based access structure for GreenLeaf Microfinance. Permissions must follow least-privilege principles and require approval from the designated system owner before implementation.

The role matrix is a proposed control design for the fictional GreenLeaf environment. It does not demonstrate that these permissions have been configured or verified in an operational system.

Role	Permitted Access	Restricted Access	Approval Authority
Adminitrator	System configuration and approved maintenance	Unnecessary borrower-data access	System Owner
GRC Lead	Security policies, audit reports and risk register	Unauthorized changes to borrower records	Management
Loan Officer	Assigned borrower records and loan processing	Other officers' records and system administration	Department Manager
Developer	Source code, development and test environments	Production borrower data and unapproved production changes	Development Lead
Auditor	Read-only access to approved audit evidence	Modifying records or configurations	GRC Lead